PHISHING URL AWARENESS

Knowledge Base for Retrieval-Augmented Generation (RAG)

Purpose
Provide a compact, structured reference for a RAG assistant that explains visible phishing-related URL warning signs.

Intended use
Local document ingestion, text extraction, chunking, embedding, retrieval and grounded answer generation.

Safety boundary
This resource supports educational URL-text analysis only. It does not authorize visiting, scanning or probing URLs.

Document type: Educational cybersecurity reference

Version: 1.0 | Prepared: November 2026

1. Phishing: Basic Concept

Phishing is a form of social engineering in which an attacker uses a deceptive message, link or website to persuade a person to disclose sensitive information or perform an unsafe action. Information targeted may include passwords, payment-card details or one-time passwords (OTPs).

A phishing URL may imitate a familiar organization, use misleading words, or place the actual destination in a part of the address that a person may overlook. A URL inspection tool can highlight selected textual clues, but a clue is not proof of malicious activity.

2. Anatomy of a URL

A URL (Uniform Resource Locator) is the address used to identify a resource. A typical URL contains a scheme, hostname and optional path, query and fragment.

```
https://www.example.com/account?mode=login#form
```

Part	Example	Meaning
Scheme	https	Indicates the protocol used in the URL.
Hostname	www.example.com	Identifies the host named in the address.
Path	/account	Identifies a resource or route on the host.
Query	?mode=login	Carries parameters after a question mark.
Fragment	#form	Points to a section or fragment within a resource.

Hostname reminder: When examining a URL, distinguish the hostname from words elsewhere in the address. For example, in `https://brand.example.invalid@destination.invalid/`, the text before the @ symbol can mislead a reader; the parsed hostname is the part after the @ symbol.

3. Six URL Warning Signs

The following checks are simple indicators used by the educational Phishing URL Awareness Checker. Each check is heuristic: legitimate URLs may trigger it, and malicious URLs may not trigger any of them.

1. @ symbol

An @ character in a URL can make the text before it look like the destination. In URL authority syntax, the portion after @ identifies the host. A reader should inspect the actual parsed hostname rather than trusting a brand name placed before @.

Example finding: Contains an @ symbol; inspect carefully.
Limitation: The character may appear in unusual but legitimate URL formats. Its presence alone does not prove phishing.

2. Unusually long URL

The workbook uses a threshold of more than 100 characters. Long addresses can make the destination harder to read, but many legitimate services use long tracking or parameterized URLs.

Example finding: Unusually long URL (over 100 characters).
Limitation: Length is a weak signal. It should be interpreted with other evidence.

3. IP address as hostname

A hostname may be written as a numeric IPv4 address instead of a recognizable domain name. The workbook's basic pattern looks for four dot-separated groups of one to three digits.

Example finding: Uses an IP address instead of a familiar domain.
Limitation: Some internal tools and legitimate services use IP addresses. A simple regular expression is a pattern check, not complete IP validation.

4. Many hostname segments

A hostname is separated into labels by dots. The workbook flags five or more labels. A long chain of subdomains can make an address visually confusing.

Example finding: Contains many hostname segments/subdomains.
Limitation: Large organizations and cloud services can legitimately use multiple subdomains.

5. Punycode marker

Punycode is an encoding used to represent internationalized domain-name labels in ASCII form. A label may begin with xn--. Look-alike characters in internationalized names can be abused to imitate familiar names.

Example finding: Contains a punycode-style hostname.
Limitation: Internationalized domain names can be legitimate. The marker is a reason to inspect, not a verdict.

6. HTTP instead of HTTPS

The workbook flags URLs whose scheme is HTTP. HTTPS provides encryption in transit and helps authenticate the server through certificates. HTTP does not provide the same transport protection.

Example finding: Uses HTTP. HTTPS alone does not prove trust.
Limitation: HTTPS does not establish that a website is honest or harmless. Phishing sites can use HTTPS too.

4. Interpretation and Risk Communication

A URL checker should communicate evidence carefully. It should report which indicators were observed and avoid claiming certainty. A count of indicators can be used as a simple display aid, but it is not a validated probability that a URL is malicious.

Recommended wording when indicators are found: “Review carefully. The URL contains one or more warning signs. These observations do not prove that the URL is malicious.”

Recommended wording when no indicators are found: “No listed warning signs found. This does NOT prove safety.”

Do not label a URL “safe” solely because it passes these six checks. A deceptive URL can avoid all six indicators, for example by using a subtly misspelled domain.

5. Safe URL-Text Inspection Workflow

A defensive educational checker can follow this local workflow:

Step	Action
1. Input	Accept a URL as a text string from the user.
2. Normalize	Trim leading and trailing whitespace. If no scheme is present, optionally prepend http:// for parsing and clearly document this behavior.
3. Parse	Use a URL parser to separate scheme, hostname and other components. Handle malformed input without crashing.
4. Inspect	Apply the six defined textual checks to the candidate URL and parsed hostname.
5. Report	List each finding and show a cautious summary. Do not claim a definitive safe/malicious verdict.
6. Explain	Retrieve relevant knowledge from this document to explain why an indicator matters and what its limitations are.

6. Educational Test Cases

These reserved example-style domains and documentation IP addresses are intended for demonstration. Treat them as text samples only; do not attempt to visit them as part of this project.

#	Sample URL text	Expected observations
1	https://www.example.com/login	No listed warning signs; this is not a safety guarantee.
2	http://192.0.2.10/account	IP-address hostname and HTTP.
3	http://example.com@sample.invalid/login	@ symbol and HTTP.
4	https://a.b.c.d.e.example.invalid/path	Many hostname segments.
5	https://xn--example.invalid/	Punycode-style hostname.

7. RAG Knowledge-Base Guidance

This PDF is intended to be ingested as a reference document. A RAG pipeline typically extracts text, divides it into chunks, converts chunks into embeddings, stores the vectors, retrieves relevant chunks for a question and supplies those chunks to a language model as context.

Suggested ingestion metadata

```
document_title: Phishing URL Awareness Knowledge Base
document_type: cybersecurity_educational_reference
topics: phishing, URL anatomy, hostname, URL warning signs, HTTP, HTTPS, punycode, safe
inspection, limitations
version: 1.0
```

Suggested chunking approach

Start with section-aware chunking so headings remain attached to their explanatory paragraphs. A practical starting point is 400–700 tokens per chunk with a small overlap of approximately 50–100 tokens. These are implementation suggestions, not requirements; compare retrieval quality using questions relevant to your application.

Suggested retrieval questions

• Why can an @ symbol in a URL be misleading?
• What does the checker mean by a long URL?
• Why might an IP address hostname deserve review?
• What is a punycode marker?
• Does HTTPS guarantee that a website is legitimate?
• What does “no listed warning signs found” mean?
• Why can a legitimate URL trigger a warning?

Grounding rule

The RAG assistant should answer from retrieved passages when explaining the six checks. If the knowledge base does not contain the requested information, it should say that the source does not specify it rather than inventing a rule. Keep detection output separate from retrieved explanations.

8. Safety, Privacy and Limitations

• Inspect URL strings only. Do not open, fetch, crawl, scan or probe submitted URLs.
• Do not send submitted URLs to external reputation services unless the project scope and user consent explicitly allow it. The EWB workbook's scope is text-only and does not include internet requests.
• Do not request or store passwords, OTPs or other credentials.
• Use the sample strings in this document for demonstration and testing.
• Do not upload secrets, personal information or confidential data into the knowledge base or public repository.
• A heuristic indicator is not proof of maliciousness.
• No warning signs found does not mean a URL is safe.

9. Glossary

Term	Definition
Phishing	A deceptive attempt to obtain sensitive information or induce an unsafe action.
URL	An address identifying a resource.
Scheme	The protocol component at the beginning of a URL, such as http or https.
Hostname	The host component identifying the server named in a URL.
Subdomain	A label placed before a registered domain, separated by a dot.
IP address	A numerical address used to identify a network interface.
Punycode	An encoding used to represent internationalized domain-name labels using ASCII characters.
Heuristic	A practical rule or signal that can help identify something but does not guarantee a correct classification.
RAG	Retrieval-Augmented Generation: a method that retrieves relevant external knowledge and uses it to ground generated responses.

End of knowledge base. This document is an educational reference and is not a threat-intelligence feed or a URL reputation database.